CYBERSENTINEL-X SECURITY OPERATIONS MANUAL

DOCUMENT VERSION: v1.0 | CLASSIFICATION: SOC OPERATIONAL GUIDANCE

SECTION 1: FALSE-POSITIVE ANALYSIS & PROTOCOL DEVIATION HANDLING

In modern enterprise networks, statistical anomaly detection engines frequently observe traffic patterns that diverge from baseline distributions without representing malicious adversarial intent. The CyberSentinel-X False-Positive Analysis Protocol establishes structured triage criteria to prevent alert fatigue.

Key Protocol Deviation Vectors:

- **RFC 2131 / RFC 3046 DHCP Option 82 Anomalies:** Relay agent information sub-options inserted by network switches or routers can trigger false-positive alerts if classified strictly against standard IP flow models. Such packets must be classified as Network Protocol Anomalies with severity LOW, rather than high-severity malicious exploit attempts.
- **Scheduled Enterprise Maintenance & Database Backups:** High-throughput intra-datacenter transfers (e.g., Veeam, rsync, NFS replication) routinely display sudden spikes in Flow Bytes/s and Total Length of Fwd Packets. SOC analysts must correlate alert timestamps against the enterprise change management calendar prior to initiating containment.
- **ML Confidence Score Interpretation:** Predictions returned by the Random Forest classifier with confidence below 80% or with high entropy across probability distributions must be tagged as 'EVALUATING' and cross-referenced with secondary telemetry before generating an automated incident report.
- **Asymmetric Routing & Straggler Packets:** TCP teardowns with delayed FIN-ACK packets following connection resets must be gracefully absorbed by the flow aggregator without spinning up duplicate flow records or false alarms.

SECTION 2: MACHINE LEARNING EXPLAINABILITY & FEATURE ATTRIBUTION

CyberSentinel-X utilizes a validated Random Forest classifier trained on 70 statistical bidirectional flow features derived from the CIC-IDS2017 benchmark dataset. To maintain analytical transparency, every prediction is accompanied by both global feature importances and local flow feature attributions.

Global Feature Hierarchy (Gini Importance Ranking):

- **Destination Port (Rank 1, Importance: 0.0688):** Primary discriminator for service targeting, separating administrative ports (22 SSH, 21 FTP) under brute-force Patator campaigns from standard HTTP/HTTPS browsing.
- **Average Packet Size (Rank 2, Importance: 0.0668):** Distinguishes automated brute-force attempts with fixed payload sizes from variable interactive user sessions.
- **Init_Win_bytes_forward (Rank 3, Importance: 0.0656):** Reflects client TCP stack characteristics; unusual initial TCP window sizes frequently identify scripted attack tooling such as Hydra, Medusa, or custom python socket scripts.
- **Packet Length Variance (Rank 4, Importance: 0.0447):** High variance indicates mixed multi-stage transfers, while zero or near-zero variance indicates repetitive probe loops or SYN floods.

Local Feature Attribution & Explainability Principles:

Local attribution scores measure the contribution of observed flow features toward shifting model output away from the benign base rate. High attribution scores explain model rationale but do not prove attacker attribution or causal identity.

Analysts must review top contributing features alongside packet hex streams to verify that anomalies correspond to genuine malicious protocol headers rather than benign transmission artifacts.

SECTION 3: SOC INCIDENT RESPONSE LIFECYCLE & CONTAINMENT FRAMEWORK

CyberSentinel-X aligns with the NIST SP 800-61 Rev. 2 Computer Security Incident Handling Guide across four primary phases: Preparation, Detection & Analysis, Containment, Eradication & Recovery, and Post-Incident Activity.

Non-Destructive Containment Protocol:

- **Analyst Approval Gate:** Autonomous systems must never unilaterally sever production connections, modify core routing tables, or block network subnets without verified human approval. All automated playbooks generate 'suggested' actions requiring explicit analyst confirmation.
- **Perimeter Firewall Rate-Limiting & DROP Rules:** For verified external brute-force source IPs (e.g. 185.73.21.10), analysts apply targeted ingress DROP rules at edge firewalls (iptables -I INPUT -s <IP> -j DROP) rather than wide subnet null-routing.
- **Target Host Isolation & Credential Revocation:** Internal hosts exhibiting post-exploitation lateral movement or C2 traffic must be logically isolated via VLAN quarantine. Associated session tokens and service accounts must be revoked immediately.

• **Recovery & Telemetry Validation:** Following eradication, target assets undergo continuous 24-hour enhanced monitoring to detect persistence mechanisms or secondary backdoors before full service restoration.

SECTION 4: FORENSIC EVIDENCE INTEGRITY & CRYPTOGRAPHIC CHAIN OF CUSTODY

Digital evidence collected during network intrusion investigations must meet strict legal and technical standards for admissibility and non-repudiation. CyberSentinel-X implements an automated SHA-256 Forensic Evidence Ledger.

Evidence Custody Standards:

- **Cryptographic Hashing:** Every raw PCAP slice, authentication log snippet, and memory artifact is hashed with SHA-256 immediately upon disk capture and registered in the immutable catalog ledger.
- **Tamper Detection & Verification:** On-demand verification recalculates the SHA-256 byte digest across disk storage. Any modification of recorded bytes immediately flags the artifact status as 'TAMPERED', generating an urgent forensic violation alert.
- **Traceable Artifact Association:** Every alert and investigation report preserves direct foreign-key references to supporting evidence IDs (e.g., EV-001, EV-002), including file path, byte length, capture timestamp, and recording block.

• **Missing Evidence Handling:** If an evidentiary file is unlinked, renamed, or purged from storage, the system explicitly returns status 'MISSING' with a detailed explanation rather than fabricating missing bytes.

SECTION 5: LANGGRAPH AGENTIC SOC INVESTIGATION ARCHITECTURE

The CyberSentinel-X investigation engine is powered by a deterministic, bounded LangGraph StateGraph comprising 9 specialized analytical nodes designed for evidence grounding and hallucination prevention.

Graph Node Execution Sequence:

1. **Validate Request:** Rejects malformed input, empty strings, and illegal parameter injections with schema-enforced HTTP 422 errors.
2. **Fetch Telemetry:** Pulls real alert records, packet counts, IP addresses, and correlated flows from SQLite.
3. **Gather Evidence:** Re-hashes associated forensic artifacts on disk to verify cryptographic SHA-256 chain of custody.
4. **Retrieve MITRE RAG:** Queries persistent ChromaDB to retrieve relevant Enterprise ATT&CK; techniques, NIST playbooks, and Knowledge Base guidelines.
5. **Correlate Hypotheses:** Contrasts competing explanations: Adversary Campaign (high likelihood) vs Benign Protocol Variance (low likelihood).
6. **Calculate Risk:** Computes deterministic risk scores using the formula: 0.45 * ThreatSeverity + 0.35 * MLConfidence + 0.20 * AssetCriticality.
7. **Generate Recommendations:** Proposes actionable containment, isolation, forensic preservation, and hardening steps labeled as 'suggested'.
8. **Synthesize Findings:** Formulates structured executive summaries grounded in observed packet evidence and source citations.
9. **Persist Report:** Commits the final investigation record into the SQLite database for permanent audit compliance.

Separation of Fact and Hypothesis:

The agentic engine explicitly separates directly observed network facts (IPs, ports, packet counts, timestamps) from AI-generated hypotheses (attack motives, threat actor attribution, potential exfiltration). Unsupported claims without evidentiary backing are strictly barred from the final persisted report.